XYZ **Holdings - Technology Services**

IS Risk Assessment and Treatment for Project Procedur e

Document Number: XYZ -TS-IS-PR-016

Classification: Internal

Owner: Chief Digital Officer (CDO)

Effective Date:15-Sep-2021

ConsultantConfidential

CS5292 W6 · D06 · sanitised for teaching

Document History:

Release Date	Revision No	Author(s)	Description	Reviewed & Approved By	Next review date
15-Sep-2021	1.0	ISO	Approved Document	ISMC	Sep-2022
05-Sep-2023	1.0	ISO	Approved Document	ISMC	Sep-2024
01-Mar-2025	2.0	ISO	Transition	ISMC	March-2026

CS5292 W6 · D06 · sanitised for teaching

Table of Contents

1. Introduction 4
1.1. Purpose 4
1.2. Scope 4
1.3. Roles and Responsibilities 4
1.4. Laws and Regulations 6
1.5. Procedure Implementation 7
1.6. Compliance 7
1.7. Review and Revision 7
2. Risk Assessment Triggers 8
2.1. Risk Assessment for Projects 8
2.2. Identifying Information Security Risks for Projects 12
Evaluation and Treatment 13
Results of The Risk Assessment 13

CS5292 W6 · D06 · sanitised for teaching

1. Introduction

1.1. Purpose

This established procedure outlines the comprehensive risk assessment and treatment process specifically designed for project implementation. Project managers and stakeholders are entrusted with the utilization of this procedure to effectively conduct and manage information security risks within the context of their respective projects.

1.2. Scope

The scope of the IS Risk Assessment and Treatment for Project Procedure is limited to the projects defined and implemented by XYZ-TS.

Project management practices must integrate information security considerations to ensure comprehensive risk mitigation, regardless of project complexity, size, duration, discipline, or application area (e.g. information technology, facility management, or supporting processes). Information security requirements will be determined for all project types.

1.3. Roles and Responsibilities

The CDO shall be accountable for the effective review, approval, communication, implementation and adoption of the IS Risk Assessment and Treatment for Project Procedure.

The Head of IT governance data protection and infrastructure services (HGDI) shall own and be responsible for the accuracy and maintenance of this procedure as well as its effective communication and implementation.

All IT Employees across XYZ Holdings shall be responsible for the effective adoption and implementation of this IS Risk Assessment and Treatment for Project Procedure.

ConsultantConfidential
CS5292 W6 · D06 · sanitised for teaching

Project Sponsor

Provides high-level guidance and support to ensure project success, strategic alignment, and adherence to information security regulations.

Responsibilities include but not limited to:

- Secures project funding and resources, including those required for information security measures.
- Removes roadblocks and facilitates project progress by managing stakeholder expectations regarding information security.
- Acts as an advocate for the project within senior management, highlighting its information security considerations.
- Approves major project changes that may impact information security and provides guidance on strategic information security decisions.

Project Owner

Represents the business needs and ensures the project aligns with overall organizational goals, including information security objectives.

Responsibilities include but not limited to:

- Approves project initiation and defines project objectives, considering information security implications.
- Provides resources and funding for information security risk assessments and mitigation strategies.
- Champions the project within the organization and secures necessary buy-in from relevant stakeholders.
- Makes final decisions on project scope changes that may impact information security posture.
- Oversees the project's information security performance and receives updates on identified risks and treatment plans.

ConsultantConfidential
CS5292 W6 · D06 · sanitised for teaching

- Approves and prioritizes information security risks requiring escalation to the Cyber Security Steering Committee (CSSC).
- Represents the project to external stakeholders, addressing any information security concerns they may raise

Project Manager

Leads the day-to-day execution of the project to achieve its objectives within budget, time, and scope constraints, and adhering to information security protocols.

Responsibilities include but not limited to:

- Develop and manage the project plan, schedule, and budget, incorporating information security considerations.
- Assigns tasks and manages the project team, ensuring awareness of information security policies and procedures.
- Identifies and mitigates information security risks throughout the project lifecycle. This includes conducting risk assessments, developing, and implementing treatment plans, and maintaining the risk register.
- Communicates project status and information security risks to relevant stakeholders (e.g., sponsor, owner, manager, CISO).
- Ensures quality control and adherence to project standards, including information security best practices.
- Manages project issues and escalates information security concerns to the appropriate level (e.g., project owner, CISO).
- Oversees project documentation and reporting, including information security aspects.

1.4. Laws and Regulations

This IS Risk Assessment and Treatment for Project Procedure shall conform to the legal and regulatory requirements of [count and any other country where XYZ Holdings conducts its business operations. These include "The Computer Crimes Act 24 of 2007 of [cour and any other

ConsultantConfidential
CS5292 W6 · D06 · sanitised for teaching

laws and regulations that may apply for the protection and preservation of individuals' rights and organizational information assets.

1.5. Procedure Implementation

This IS Risk Assessment and Treatment for Project Procedure shall be implemented through effective user awareness and training, engagement of key operational teams in formalizing and following information security best practices in project management in XYZ-TS.

1.6. Compliance

Systems and services provided by XYZ-TS are the property of XYZ-TS. This gives XYZ-TS the right to monitor all activities performed using these resources.

Users shall maintain continued compliance with all XYZ-TS policies, procedures, guidelines, rules, and administrative orders while using XYZ-TS systems, facilities and/or services.

The Chief Digital Officer shall designate persons to perform periodic reviews and provide relevant feedback on the design and operating effectiveness of this procedure.

Non-compliances to this procedure shall be recorded and responded through the Incident and Problem Management procedure.

If XYZ-TS discovers or has good reason to suspect activities that do not comply with applicable laws or policies, activity logs or records may be retrieved and used/ presented as evidence for disciplinary action against the involved user.

1.7. Review and Revision

This IS Risk Assessment and Treatment for Project Procedure shall be periodically reviewed and updated to reflect changes in the organization, operating environment, local laws and regulations and leading practices as well as recommendations provided by consultants/ advisors, and internal and external auditors.

ConsultantConfidential
CS5292 W6 · D06 · sanitised for teaching

The procedure review and revision period shall not exceed one Calendar year.

2. Risk Assessment Triggers

- Projects will be initiated via following channels:
  - Business initiated projects.
  - Information Systems Division initiated projects.
  - Technology-initiated projects; and
  - Changes to existing projects.
- Requests are initiated by Business division for business-initiated projects and send Senior Management for approval.
- Requests are initiated by TS division for Technology-initiated projects and sent to CDO or TS Leadership.
- For Changes in existing projects, it will be triggered by project managers and the CDO or TS Leadership will approve it
- Once the project is approved, the project manager where the project is been initiated in XYZ-TS is required to perform an information security risk assessment using this procedure.

2.1. Risk Assessment for Projects

Identification

- Prior to project kickoff, the team lead, in collaboration with the Department Heads, Legal, Project Team ,Information Security (IS) Officer, and any other respective stakeholders must identify information security objectives and associated risks.
- Information security requirements for project deliverables (products or services) will be determined through various approaches including but not limited to:
  - XYZ's information security policy and relevant topic-specific policies or regulations.
  - Threat modeling exercises and comprehensive reviews of past security incidents.

ConsultantConfidential
CS5292 W6 · D06 · sanitised for teaching

- Established contingency plans, ensuring that all systems possess the necessary resilience to withstand potential disruptions. This ensures business continuity in the event of unforeseen circumstances.
- Access provisioning and authorization protocols will govern all users interacting with project deliverables. This encompasses customers, internal business users, privileged users (including project members and operations staff), and any involved external suppliers.
- Strict adherence to relevant intellectual property rights, including copyright law, patent law, and trademark law (depending on the specific context of the project), will be mandatory.
- All project deliverables must demonstrably align with the legal, statutory, regulatory, and contractual requirements that govern the XYZ's operations.

- Throughout the project lifecycle, the XYZ conducts information security risk assessments for all projects, including those involving third-party vendors.

Project managers are responsible for documenting identified information security risks and the corresponding risk treatment actions implemented.

Analysis

- The following information security risks should be considered during project risk assessments:
  - Possibility of data loss:
    - Information disclosures to unauthorized third parties.
    - Information leakage during project activities.
    - Unauthorized access to critical XYZ information.
  - Potential system disruption:
    - Project-induced instability affecting existing information security controls.
    - Changes to information systems or IT infrastructure.
    - Resource unavailability impacting project execution.
  - Business continuity:

ConsultantConfidential
CS5292 W6 · D06 · sanitised for teaching

- Disaster recovery and business continuity capabilities during project implementation.
- Backup and archival procedures.
- External Hosting: This includes risks associated with:
  - Results from vulnerability assessments for systems hosted within the XYZ's IT infrastructure.

- Following the identification of information security risks, project managers will define trigger points. These trigger points indicate when risk treatment actions become necessary during project execution.
- The project manager shall assess the risk with its impact and likelihood using the following table and assign values accordingly.

Impact Rating	Guideline
4 – Extreme	• Materializing the risk will create catastrophic financial and reputational impact. • Customer information, XYZ's critical information, and sensitive information will be disclosed to an outside party.
3 – High	• Materializing the risk will create a serious financial and reputational impact. • Customer information, XYZ's critical information, and sensitive information will be disclosed to an outside party.
2 – Medium	• Materializing the risk will create significant financial and reputational impact • Customer information, higher chance of critical information and sensitive information may be disclosed to an outside party.
1 – Low	Minimal disruption to sustainable and ethical manufacturing processes, with slight delays or adjustments needed in technology integration. Impact is limited to small-scale operational changes with no significant effect on industry reputation.

Table 1:Impact Rating

Risk Likelihood	Rating Guideline

ConsultantConfidential
CS5292 W6 · D06 · sanitised for teaching

Unlikely (1)	The event could occur annually
Prosible(2)	The event may occur bi-annually
Likely (3)	The event is expected to occur quarterly
Almost Certain (4)	The event is expected to occur monthly

Table 2: Likelihood Rating

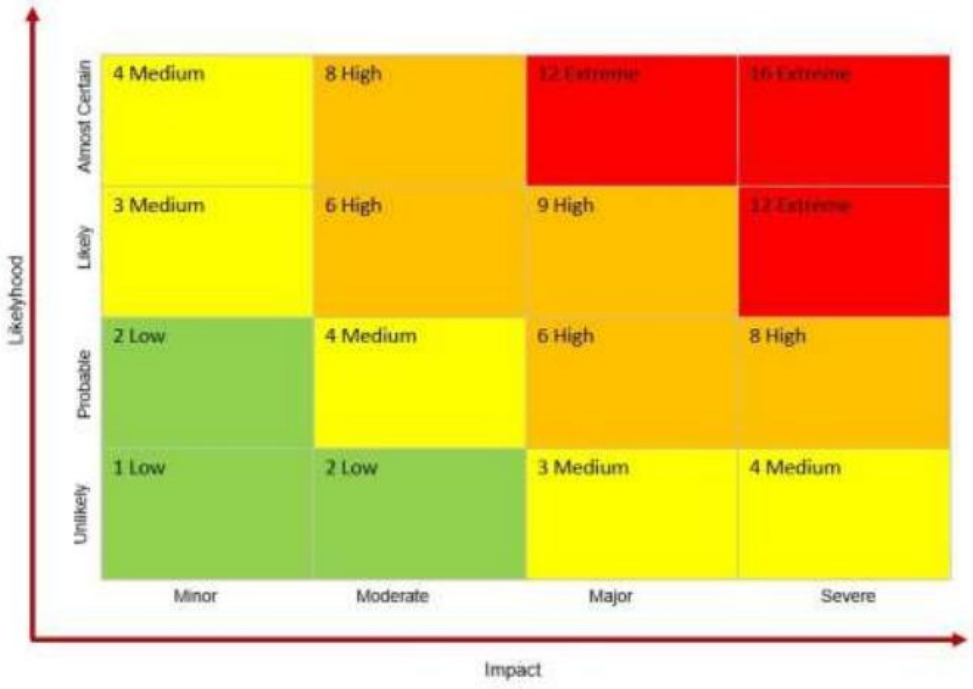


Table 3: Risk Matrix

From	To	Priority
1	3	Low
4	6	Medium
8	9	High
12	16	Extreme

Table 4: Risk Classification

ConsultantConfidential
CS5292 W6 · D06 · sanitised for teaching

2.2. Identifying Information Security Risks for Projects

- Project manager shall use the template given in annexure A - IS for Projects Risk Register of this document to perform the risk assessment.
- Following information security risks shall be considered as applicable for the risk assessment.
  - Information disclosures to any third parties;
  - Information leakage points during project;
  - Access to critical XYZ-TS information due the project;
  - Instability that may create because of the project to the existing ISMS;
  - Disclosure of any customer information;
  - Changes to any existing information systems;
  - Changes to any existing IT infrastructure;
  - Unavailability of resources;
  - Disaster recovery and business continuity aspects;
  - Backup and archival;
  - For any system hosted outside vulnerability assessment; and
  - Health and safety requirements.

- Once information security risks are identified, project manager shall identify the trigger points. Trigger points are where the point of time of the project where the risk may materialize.
- Team Lead shall assess the risk with its impact and probability using the following table and assign values.
- Rating, Impact calculations and risk acceptance are same as the Risk Assessment and Treatment Procedure.
- After determining the Risks may be accepted only if the project sponsors approve such risks.
- Information security objectives, information security risks and action plan shall be documented and approved by the ISO.

ConsultantConfidential
CS5292 W6 · D06 · sanitised for teaching

- Risk assessment is an ongoing process till the project closes and Team Leads shall be responsible to update the risk assessment.

Evaluation and Treatment

- Risks categorized within the range of Three (3) to Sixteen (16) on the established risk severity scale mandate the development and execution of corresponding risk treatment plans.
- The project manager can take the following actions to manage such risks:
  - Control and mitigate;
  - Transfer;
  - Avoid; or
  - Accept.
- Risk mitigation strategies may only be deemed sufficient, and subsequent risk acceptance authorized, following a comprehensive review and approval by the Information Security Management Committee (ISMC).
- Project Owners have the authority to approve information security objectives, risks, and action plans for projects with a risk value below Three (3).
- Project risks with a value of Three (3) and above require review and approval by the Project Owner (in consultation with the Head of Department/CDO) along with their corresponding action plans.
- The project risk assessment process is a continuous exercise that undergoes iterative revisions throughout the entire project lifecycle. The Project Manager bears the responsibility for ensuring the ongoing maintenance and updates to both the risk assessment itself and the corresponding risk treatment plans.

Results of The Risk Assessment

- The project Manager takes responsibility for managing information security risks. This includes maintaining the risk register, updating information security risk assessments, and corresponding treatment plans, and presenting risks to the Information Security Management Committee (ISMC) meetings for review throughout the project lifecycle.
- To ensure information security throughout the project lifecycle, the project owner reviews progress on risk treatment plans, continuously evaluating and testing their effectiveness.

ConsultantConfidential
CS5292 W6 · D06 · sanitised for teaching